

1. Evidence (label each clearly)

- The 401 (no credentials) and 200 (valid credentials) results (Task 1).

```
(melon@melon)-[~]  
$ curl -s -o /dev/null -w 'no-creds: %{http_code}\n' http://localhost:8080  
# 401  
no-creds: 401
```

```
(melon@melon)-[~]  
$ curl -s -u student:'m3l0n!' -o /dev/null -w '%{http_code}\n' http://local  
host:8080  
200
```

- The MFA OK output for a valid TOTP code (Task 2).

```
(melon@melon)-[~]  
$ # Create a shared secret (base32) and generate the current 6-digit code  
SECRET=$(head -c20 /dev/urandom | base32)  
echo "Enrol this secret in an authenticator app: $SECRET"  
oathtool --totp -b "$SECRET"  
  
# Validate a code the user types (compare to the expected value)  
read -p 'Enter the 6-digit code: ' CODE  
[ "$CODE" = "$(oathtool --totp -b "$SECRET")" ] && echo 'MFA OK' || echo 'MFA  
FAILED'  
Enrol this secret in an authenticator app: QVPUCIKMAER254BZSPIPS3N05SZBQQJC  
330650  
Enter the 6-digit code: 330650  
MFA OK
```

- The three auth can-i results — allowed vs denied (Task 3).

```
(melon@melon)-[~]  
$ SA=system:serviceaccount:app:dev  
kubectl auth can-i list pods -n app --as=$SA # yes  
kubectl auth can-i create deployments -n app --as=$SA # no  
kubectl auth can-i delete pods -n app --as=$SA # no  
no or from server (already exists); namespaces 'app' already e  
no or failed to create serviceaccount: serviceaccounts 'dev'
```

- web→db BLOCKED and app→db REACHABLE (Task 4).

```
(melon@melon)-[~]
$ # web → db should FAIL (not on the same network)
docker exec web sh -c 'apk add -q curl; curl -s -m 3 db:6379 || echo BLOCKED'
BLOCKED
# app → db should WORK (shared backend-net)
docker exec app sh -c 'apk add -q curl; nc -z -w3 db 6379 && echo REACHABLE'
REACHABLE
```

- The iptables default-deny ruleset (Task 5).

```
(melon@melon)-[~]
$ docker run --rm --cap-add=NET_ADMIN alpine sh -c '
apk add -q iptables
iptables -P INPUT DROP
iptables -A INPUT -p tcp --dport 443 -j ACCEPT
iptables -A INPUT -i lo -j ACCEPT
iptables -L INPUT -n
'
```

Chain INPUT (policy DROP)

target	prot	opt	source	destination
ACCEPT	tcp	--	0.0.0.0/0	0.0.0.0/0
ACCEPT	all	--	0.0.0.0/0	0.0.0.0/0

- The hardened container inspect output and the Trivy scan summary (Task 6).

```
(melon@melon)-[~]
$ docker inspect hardened --format 'User={{.Config.User}} ReadOnly={{.HostC
onfig.ReadOnlyRootfs}}'
User=1000:1000 ReadOnly=true
```

Report Summary

Target	Type	Vulnerabilities	Secrets
nginx:alpine (alpine 3.24.1)	alpine	7	-

Legend:

- '-': Not scanned
- '0': Clean (no security findings detected)

nginx:alpine (alpine 3.24.1)

Total: 7 (HIGH: 7, CRITICAL: 0)

Library	Vulnerability	Severity	Status	Installed Version	Fixed Version
		Title			

Notices:

- Version 0.74.0 of Trivy is now available, current version is 0.72.0

To suppress version checks, run Trivy scans with the --skip-version-check flag